PRADITA University

IT40813 · IT Governance, Risk & Compliance

Pelindungan Data Pribadi dalam Praktik

Pertemuan 07

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Data, Tujuan, dan Dasar
3. Peran
4. Hak Subjek Data
5. Catatan Pemrosesan
6. Lokasi dan Transfer
7. Penilaian Dampak
8. Pemberitahuan

PRADITA University

Data pasien bocor lewat vendor. Siapa wajib memberi tahu pasien, dan mulai kapan dihitung?

Tujuan Pembelajaran

- Menjelaskan kewajiban pengendali dan prosesor data pribadi menurut UU 27/2022 dan ketentuan pelaksana yang terverifikasi.
- Menyusun catatan kegiatan pemrosesan data pribadi untuk satu proses layanan.
- Menganalisis insiden kebocoran data dan menilai apakah penanganannya memenuhi kewajiban notifikasi.

Masalah: Kebocoran Terjadi pada Vendor

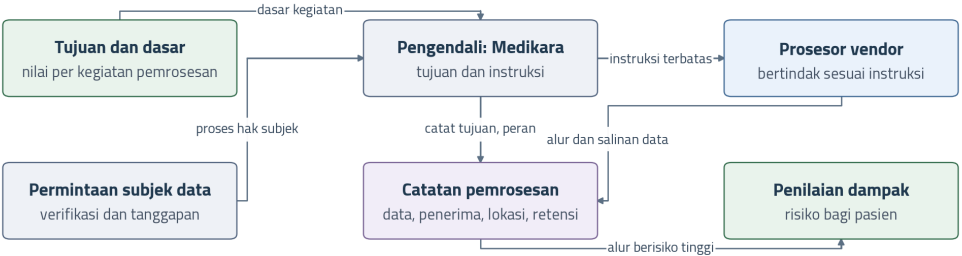
PRADITA University

- Data latihan: akun dukungan tetap aktif setelah kontrak selesai.
- 155 panggilan per malam selama 8 malam, atau 1.240 rekam kunjungan pada dua rumah sakit.
- Medikara baru mengetahuinya pada hari ke-11, lewat keluhan pasien.
- Bab ini menutup C2: melanjutkan K-01 sampai K-16, R-01, R-12, dan G-01 sampai G-06.
- Bukan nasihat hukum. Pembacaan pasal yang perlu penilaian ditandai “penafsiran bab”.

Diagram Konsep Bab 7

IT40813 / BAB 07 / DIAGRAM KONSEP

Tujuan dan dasar pemrosesan mengendalikan alur data pribadi



Persetujuan bukan satu-satunya dasar pemrosesan. Retensi serta transfer dinilai bersama aturan sektor dan tujuan masing-masing.

Data Umum dan Data Spesifik

Data	Jenis menurut Pasal 4	Akibat pada pengelolaan
Nama dan jenis kelamin pada pendaftaran	Umum	Tetap perlu dasar, tujuan, dan pengamanan
Diagnosis, hasil laboratorium, resep	Spesifik: kesehatan	Potensi risiko tinggi, Pasal 34 ayat (2) huruf b
Nama dan poli pada janji temu	Gabungan; diperlakukan spesifik (penafsiran bab)	Akses dibatasi seperti data klinis
Data pasien anak	Spesifik: data anak	Persetujuan orang tua atau wali, Pasal 25

Analogi buku tamu: nama di buku tamu poli jantung sudah bercerita tentang kesehatan.

Tujuan Membatasi Pemrosesan

- Pasal 16 ayat (2): terbatas dan spesifik, sah, transparan, sesuai tujuan, aman, dapat dibuktikan.
- Analogi kunci rumah: izin memperbaiki keran bukan izin membuka seluruh lemari.
- 28.000 janji temu per bulan memuat nama dan poli tujuan.
- IT40613: 4 bidang menjadi 10 bidang menaikkan paparan 1.240 rekam dari 4.960 menjadi 12.400 butir data.
- Bidang yang tidak pernah dikirim tidak dapat bocor lewat jalur itu.

Enam Dasar, Bukan Satu Kotak Persetujuan

PRADITA University

Tujuan	Dasar kandidat (penafsiran bab)	Bila pasien menolak atau menarik
Pendaftaran janji temu	Perjanjian atau permintaan subjek data, Pasal 20 ayat (2) huruf b	Layanan daring tidak berjalan; pasien memakai loket
Pelayanan dan rekam medis	Kewajiban hukum, huruf c; UU 17/2023 Pasal 296, PP 28/2024 Pasal 779	Pencatatan tetap berjalan; retensi 25 tahun tetap berlaku
Gawat darurat, pasien tidak sadar	Kepentingan vital, huruf d	Persetujuan tidak dapat diminta saat itu
Pembukaan rekam medis untuk asuransi	Persetujuan, huruf a; Permenkes 24/2022 Pasal 34 ayat (1) huruf c	Klaim lewat jalur itu berhenti; perlu jalur lain
Promosi layanan lain	Persetujuan terpisah, huruf a	Keluar dari daftar paling lambat 3×24 jam

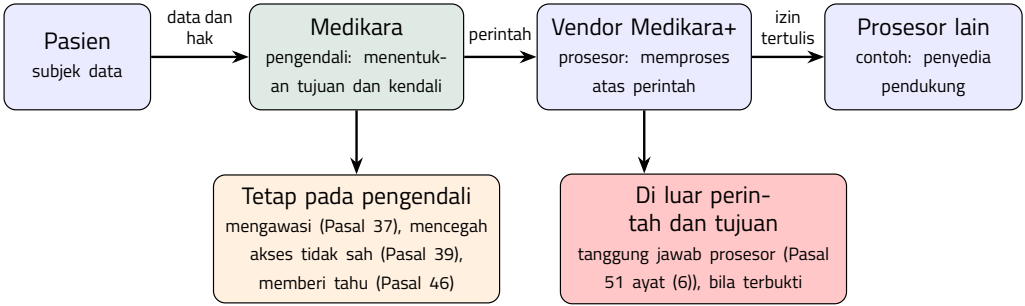
PP 28/2024 Pasal 963 ayat (1): persetujuan dan/atau dasar lain.

Kasus Medikara: Satu Kotak untuk Tiga Tujuan

PRADITA University

- Misalkan satu kotak centang dipakai 336.000 janji temu per tahun. Pasal 22 ayat (4) meminta tujuan lain dapat dibedakan.
- Daftar promosi 2.000 pasien dibekukan. Misalkan 40 persen setuju kembali: 800 pasien.
- Bila 150 pasien menarik persetujuan, daftar 2.000 turun menjadi 1.850 dalam 3×24 jam.
- Rekam medis berdasar persetujuan berbenturan dengan retensi 25 tahun.
- Persetujuan menuntut bukti: Pasal 24 dan Pasal 22 ayat (5).

Pengendali, Prosesor, dan Tanggung Jawab



Pasal 1, Pasal 51, Pasal 52. Analogi penitipan dokumen: pemilik menentukan tujuan, penyedia menjalankan instruksi. Penafsiran bab.

Pertanyaan untuk Menentukan Tanggung Jawab

PRADITA University

Pertanyaan	Bukti	Akibat keputusan
Siapa menentukan tujuan?	Kebijakan layanan dan keputusan bisnis	Tentukan pengendali per kegiatan
Siapa memberi instruksi?	Kontrak serta perubahan instruksi	Batasi tindakan prosesor
Siapa melibatkan pihak lain?	Persetujuan tertulis dan daftar prosesor lain	Pasal 51 ayat (5) dapat diuji
Siapa menangani permintaan pasien?	Alur permintaan dan catatan tanggapan	Cegah pasien dipingpong
Siapa memberi tahu saat kegagalan?	Prosedur insiden dan bukti pengiriman	Pengendali memiliki data tepat waktu

Kasus Medikara: Akun Dukungan di Luar Penugasan

PRADITA University

- Siapa bertanggung jawab atas 1.240 rekam? Bila terbukti di luar perintah, Pasal 51 ayat (6) mengarah ke vendor.
- Bukti belum lengkap: catatan hanya memuat ID aplikasi, bukan ID orang.
- Siapa wajib memberi tahu pasien? Pasal 46 menyebut pengendali, yaitu Medikara.
- Pasal 37 dan 39 tetap berlaku: 12 dari 120 akun luput dari peninjauan.
- Klausul 12 jam (K-05) tidak menggantikan Pasal 46. Pembacaan ini penafsiran bab.

Fungsi Pelindungan Data dan Putusan MK

- Pasal 53 ayat (1) memuat tiga keadaan. Putusan MK 151/PUU-XXII/2024: kata “dan” pada huruf b dimaknai “dan/atau”.
- Medikara: sekitar 1,2 juta kunjungan per tahun, data kesehatan sebagai kegiatan inti.
- Misalkan 1 petugas penuh waktu dan 5 koordinator 20 persen: setara 2 orang, 320 jam per bulan.
- Kepala TI tidak dipilih, karena ia ikut menentukan cara pemrosesan.
- Analogi petugas keselamatan kerja: memeriksa, tetapi tidak mengoperasikan mesin.

Hak, Batas, dan Bukti

Hak	Pasal	Batas	Pemilik	Bukti
Akses dan salinan	7, 32	3×24 jam sejak diterima	Rekam medis	Tiket dan pengiriman
Perbaikan	6, 30	3×24 jam sejak diterima	Rekam medis	Jejak perubahan
Menarik persetujuan	9, 40	3×24 jam sejak diterima	Pemasaran	Daftar sebelum dan sesudah
Menunda atau membatasi	11, 41	3×24 jam sejak diterima	Fungsi privasi	Pengaturan sistem
Mengakhiri dan menghapus	8, 42, 43, 44	Tanpa rentang jam; mengikuti peraturan	Fungsi privasi	Keputusan dan alasan

Analogi loket berkas: nomor antrean, periksa identitas, nilai, simpan tanda terima.

Dua Contoh: Beban dan Penghapusan

PRADITA University

- Misalkan 0,1 persen dari 28.000 janji temu: 28 permintaan per bulan, 45 menit per permintaan.
- Beban 21 jam per bulan, 252 jam per tahun, sekitar 1,6 bulan kerja.
- Permintaan Jumat 16.00 selesai Senin 16.00. Loket Senin sampai Jumat hanya punya 9 jam kerja.
- Pasien terakhir berkunjung 2 Maret 2026: rekam medis paling singkat sampai 2 Maret 2051.
- Hapus dari daftar promosi, jelaskan alasan rekam medis tidak dihapus, catat keduanya.

Catatan Pemrosesan: Satu Baris per Kegiatan

PRADITA University

- Pasal 31: pengendali merekam seluruh kegiatan pemrosesan. RoPA adalah nama lembar kerja.
- Analogi kartu persediaan: asal, tujuan, lokasi, dan masa simpan barang.
- Catatan dukungan 90 hari: sekitar 84.000 baris. Disalin 25 tahun: 8,4 juta baris, 100 kali.
- 6 proses pada 36 fasilitas: 216 baris atau 144 jam. Dikelompokkan: 28 baris, sekitar 19 jam.
- Salinan pihak ketiga PP 33/2026 Pasal 74 menyebut 13 butir: dipantau, belum kewajiban.

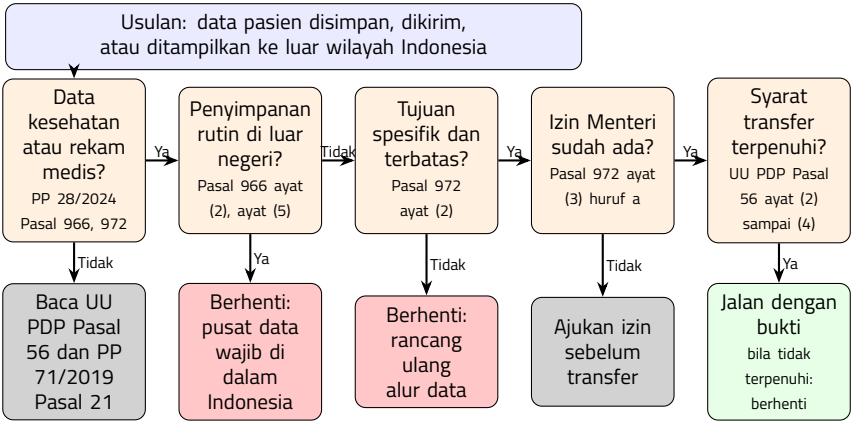
Contoh Catatan Pemrosesan (Misalkan)

Butir	P-01 Pendaftaran	P-02 Telekonsultasi	P-05 Dukungan vendor
Tujuan, pemilik	Janji temu; pemilik Medikara+	Pelayanan jarak jauh; pemilik rekam medis	Perbaikan gangguan; pengelola vendor
Data	Identitas, poli, jadwal	Keluhan dan catatan klinis	Data tiket; akses baca terbatas
Dasar	Perjanjian, huruf b	Kewajiban hukum, huruf c	Perjanjian; instruksi tertulis
Penerima	Vendor sesuai instruksi	Tenaga kesehatan berwenang	Staf vendor yang ditugaskan
Lokasi	Harus dikonfirmasi	Pusat data dalam negeri	Harus dikonfirmasi
Retensi	Ditetapkan per tujuan	Mengikuti rekam medis	90 hari
Bukti	Dasar, instruksi, akses	Dasar, akses, jejak perubahan	AC-01 dan daftar 120 akun

Dua Masa Simpan yang Sering Tertukar

- Rekam medis: paling singkat 25 tahun sejak kunjungan terakhir, Permenkes 24/2022 Pasal 39.
- Catatan akses: berapa lama organisasi dapat membuktikan siapa membaca apa.
- Catatan rinci 7 hari, diketahui hari ke-11: 620 rekam terlacak, 620 rekam tinggal jumlah.
- Pasal 46 ayat (2) huruf a meminta data yang terungkap. Separuh rekam tidak dapat dijawab.
- Dinaikkan menjadi 90 hari: ruang simpan sekitar 12,9 kali, dan perlu baris RoPA sendiri.

Lokasi dan Transfer: Dua Lapis Aturan



Urutan pertanyaan adalah penafsiran bab.

Dua Contoh: Penawaran Murah dan Dukungan Jarak Jauh

PRADITA University

- Bab 3: penawaran luar negeri Rp420 juta, hemat Rp180 juta atau 30 persen dari Rp600 juta.
- Persetujuan pasien pada Pasal 56 tidak menjawab Pasal 966 ayat (2) PP 28/2024.
- Misalkan 4 staf vendor di luar negeri membuka layar untuk sekitar 300 tiket per bulan.
- Pasal 971 ayat (2) menyebut penampilan sebagai bentuk transfer (penafsiran bab).
- Dukungan dalam negeri misalkan lebih mahal Rp25 juta per bulan, atau Rp300 juta per tahun.

Penyaringan Tiga Usulan terhadap Pasal 34 Ayat (2)

Keadaan	Klaim asuransi	Triase otomatis	Tampilan baru
a. Keputusan otomatis	Tidak	Ya	Tidak
b. Data spesifik	Ya	Ya	Sudah ada, tidak berubah
c. Skala besar	Ya: 72.000 per tahun	Perlu dihitung	Sudah ada, tidak berubah
d. Evaluasi atau pemantauan	Tidak	Ya: penskoran gejala	Tidak
e. Penggabungan data	Ya	Tidak	Tidak
f. Teknologi baru	Tidak	Ya	Tidak
g. Membatasi hak	Perlu diperiksa	Perlu diperiksa	Tidak
Keputusan	DPIA sebelum aktif	DPIA sebelum uji coba	Tinjau DPIA lama bila alur berubah

DPIA: Risiko bagi Pasien, Bukan Hanya Organisasi

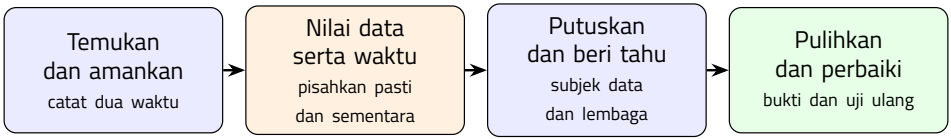
PRADITA University

- Analogi ruang operasi baru: pemeriksaan dilakukan sebelum pasien masuk.
- 5 dari 6 proses memuat data kesehatan: 5 kali 72 jam, atau 360 jam dan Rp21,6 juta.
- Pembanding WP 248 rev.01: dua kriteria pada umumnya perlu DPIA. Pasal 34 tidak memuat aturan itu.
- R-01 berskor $3 \times 4 = 12$ dan Rp100 juta per tahun. Itu risiko bagi organisasi.
- Satu rekam poli kejiwaan terungkap: dampak 1 bagi Medikara, tetapi stigma bagi pasien.

Pasal 46: Isi Kewajiban

- Ayat (1): pemberitahuan tertulis paling lambat 3×24 jam kepada subjek data dan lembaga.
- Ayat (2): data terungkap, kapan dan bagaimana, serta penanganan dan pemulihan.
- Ayat (3): kepada masyarakat dalam hal tertentu.
- Contoh dasar: kegagalan dan penemuan bersamaan Jumat 20.00, batas Senin 20.00 WIB.
- Varian Bab 3: vendor melapor setelah 30 jam, kontrak terlewati 18 jam, sisa 42 jam.

Alur Keputusan Insiden



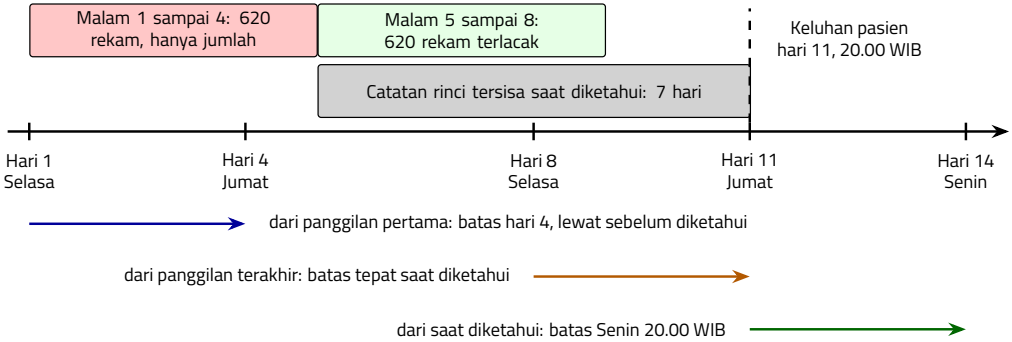
Analogi peringatan kerusakan produk: menunggu seluruh penyebab membuat pengguna terus terpapar. Waktu kejadian dan waktu diketahui dicatat terpisah.

Kapan Rentang 72 Jam Mulai Dihitung?

PRADITA University

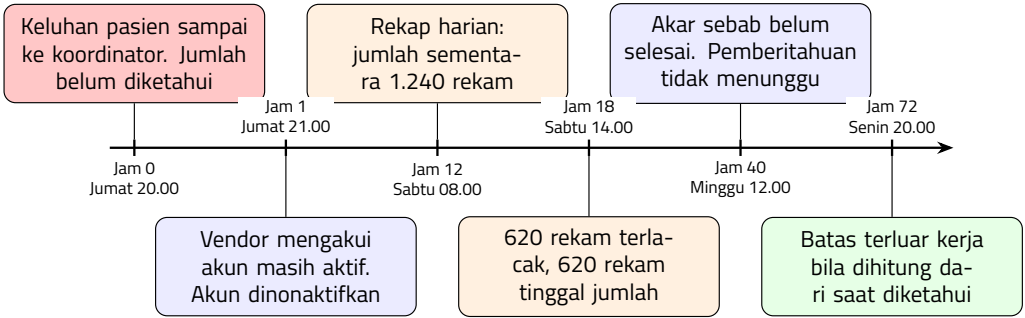
- Pasal 46 ayat (1) tidak menulis titik mulai. Pasal 30, 32, 40, dan 41 menulis "terhitung sejak".
- Salinan pihak ketiga PP 33/2026 Pasal 114 ayat (2): "diketahui secara pasti, patut, dan wajar". Naskah resmi belum diperoleh; mulai berlaku 16 Januari 2027. Hanya dipantau.
- GDPR dan EDPB: tingkat kepastian yang wajar. Hanya pembanding.
- Sikap kerja (penafsiran bab): batas terluar dihitung dari saat pertama diketahui.
- Fungsi hukum, pemilik R-12, menetapkan batas operasional konservatif.

Insiden 2025: Tiga Pembacaan Rentang 72 Jam



Dari panggilan pertama, batas lewat 168 jam sebelum Medikara tahu. Jam adalah pengandaian.

Jam-Jam Pertama: Angka Belum Pasti



Jumlah sementara tersedia pada jam ke-12. Pada jam ke-18, 25 persen rentang sudah terpakai.

Kasus Medikara: Isi Pemberitahuan Senin Pagi

Unsur Pasal 46 ayat (2)	Sudah pasti	Sementara atau belum diketahui
Data yang terungkap	Rekam kunjungan pada dua rumah sakit	Jumlah 1.240 dari rekap; 620 rekam belum terhubung ke nama
Kapan dan bagaimana	8 malam, lewat akun dukungan vendor yang aktif setelah kontrak selesai	Orang yang memakai akun; apakah data disalin keluar
Penanganan dan pemulihan	Akun dinonaktifkan; 120 akun diperiksa	Akar sebab; hasil pemeriksaan di sisi vendor

Tim tidak menunggu angka final. Cara bertahap dicatat bersama fungsi hukum.

Kasus Medikara: 620 Rekam yang Tidak Terlacak

Pilihan	Biaya langsung	Kelemahan
A. Hanya 620 pasien terlacak	Rp9,3 juta	620 rekam lain tanpa pemberitahuan
B. A, pengumuman, dan kanal tanya jawab	Rp9,3 juta ditambah Rp4,8 juta: Rp14,1 juta	Pesan umum tidak menjamin terbaca
C. Pesan ke seluruh kunjungan dua rumah sakit	360.000 pesan kali Rp500: Rp180 juta	Sebagian besar tidak terdampak

Misalkan tim mengusulkan B: biaya langsung naik dari Rp23,7 juta menjadi Rp28,5 juta. Fungsi hukum menilai Pasal 46 ayat (3).

Membaca Dua Penelitian

- McCoy dan Perlis (2018): 2.149 pelanggaran, 176,4 juta rekam di Amerika Serikat, 2010 sampai 2017.
- Penyedia layanan: 70 persen pelanggaran, 21 persen rekam. *Health plan*: 13 persen dan 63 persen.
- Choi dan rekan (2019): 3.025 rumah sakit. Sesudah pelanggaran, waktu sampai elektrokardiogram naik hingga 2,7 menit.
- Mortalitas 30 hari infark miokard akut naik hingga 0,36 poin persentase. Ini asosiasi.
- Angka tidak disalin ke Medikara. Kontrol baru diuji dampaknya pada pelayanan klinis.

Status Sumber Hukum per 1 November 2026

PRADITA University

Sumber	Status kerja	Tindakan
UU 27/2022	Naskah resmi terbaca; Pasal 74 berakhir 17 Oktober 2024	Turunkan kewajiban serta bukti
Putusan MK 151/PUU-XXII/2024	Amar resmi terbaca	Baca bersama Pasal 53
PP 28/2024; Permenkes 24/2022	Naskah resmi terbaca	Turunkan kewajiban sektor
PP 33/2026	Salinan pihak ketiga dan ringkasan; naskah resmi belum diperoleh	Pantau; jangan menetapkan pasal sebagai kewajiban
Perpres dan lembaga	Berita Juli dan September 2026; naskah belum ditemukan	Tetapkan penanggung jawab kanal
Peraturan lembaga	Belum ditemukan	Pantau

Analogi jadwal perjalanan: pengumuman rute baru belum berarti jadwal dapat dipesan.

Sanksi dan Masa Penyesuaian

- Pasal 57: peringatan, penghentian sementara, penghapusan, dan denda paling tinggi 2 persen.
- Misalkan variabel Rp500 miliar: paling tinggi Rp10 miliar, sekitar 422 kali Rp23,7 juta. Alat diskusi, bukan perkiraan.
- Pasal 67 ayat (1): 5 tahun dan/atau Rp5 miliar, dengan unsur sengaja dan melawan hukum.
- Pasal 74 berakhir 17 Oktober 2024. Insiden 2025 tidak punya alasan “masih masa penyesuaian”.
- PP 33/2026 berlaku 2027, sehingga tidak dipakai menilai kejadian 2025 (penafsiran bab).

Sistem Manajemen Privasi dan Celah C2

PRADITA University

- ISO/IEC 27701:2025 tentang PIMS kini standar mandiri. Sertifikat tidak menggantikan analisis dasar.
- Uji sampel: 12 dari 150 pasien yang menarik persetujuan masih menerima promosi, 8 persen.
- Kode CP-01 sampai CP-07 melanjutkan G-01 sampai G-06. Tabel lengkap ada pada modul.
- Misalkan tiga prioritas: CP-04 pemberitahuan, CP-01 perjanjian vendor, CP-05 catatan rinci.
- Latihan pemberitahuan dua kali setahun: 12 orang, 4 jam, atau 96 jam dan Rp5,76 juta.

Aktivitas: Peran dan Langkah

- Analis regulasi memimpin. Pemilik konteks memetakan alur. Analis teknologi menelusuri sistem. Analis risiko memperbarui R-01 dan R-12.
- Isi catatan pemrosesan untuk pendaftaran atau telekonsultasi, lalu uji lokasi datanya.
- Saring proses dengan tujuh keadaan Pasal 34.
- Susun kronologi, isi analisis celah, dan buat rancangan pemberitahuan yang tidak dikirim.
- Rangkum Bab 4 sampai 7 menjadi C2, lalu bawa tiga celah ke C3.

Aktivitas: Luaran, C2, dan Berkas

PRADITA University

- Luaran: RoPA, penyaringan DPIA, analisis insiden, rancangan pemberitahuan, celah PDP.
- Tonggak C2 Kondisi Saat Ini, ditinjau menjelang UTS.
- Rubrik: dasar dan peran 30 persen, alur 25 persen, kronologi dan tenggat 30 persen, bukti 15 persen.
- Berkas di `sources/chapter07`: `catatan-pemrosesan.csv`, `analisis-celah-pdp.md`, `kronologi-insiden-vendor-2025.md`, `templat-notifikasi.md`, dan lainnya.
- Data nyata wajib berizin dan dianonimkan. Data pasien tidak boleh dipakai.

Ringkasan

- Pasal 20 menyediakan enam dasar. Persetujuan hanya salah satunya.
- Peran dinilai per kegiatan. Kewajiban memberi tahu tetap pada pengendali.
- RoPA memperlihatkan alur data. Pasal 966 dan 972 PP 28/2024 dibaca bersama Pasal 56.
- DPIA menilai akibat bagi pasien sebelum alur berjalan.
- Pasal 46 tidak menulis titik mulai. Dua waktu dicatat, dan angka sementara disebut sementara.

Latihan

1. Medikara memakai vendor untuk aplikasi Medikara+. Dalam hubungan ini, siapa pengendali dan siapa prosesor? Apa akibatnya terhadap tanggung jawab saat terjadi kebocoran?
2. Tentukan dasar pemrosesan yang paling tepat untuk data rekam medis dalam layanan pengobatan. Jelaskan mengapa persetujuan belum tentu menjadi dasar yang terbaik.
3. Susun garis waktu notifikasi yang memenuhi UU PDP untuk insiden yang ditemukan pada Jumat malam.

Tabel contoh dan lembar isian tersedia pada modul.

Bacaan dan Pesan Utama

UU 27/2022, Putusan MK 151/PUU-XXII/2024, PP 28/2024, Permenkes 24/2022
WP 248 rev.01, McCoy dan Perlis (2018), Choi dan rekan (2019)

Organisasi harus dapat menunjukkan alasan pemrosesan, kendali alur data, dan bukti pertanggungjawabannya.